

SEC105 - Architectures et bonnes pratiques de la sécurité des réseaux, des systèmes, des données et des applications

Concepteur Architecte Informatique (toutes spécialités)

1

Objectif : comprendre le fonctionnement et les vulnérabilités, configurer, exploiter, superviser les exigences de sécurité de base sur les données stockées et véhiculées dans les systèmes mobiles, lors de synchronisations d'ordinateur, Cloud des données personnelles, professionnelles, identifiants numériques en mobilité.

Thème : Architectures et protocoles pour la protection des données travail, domicile & mobilité

Préambule

- Le développement du nomadisme et du télétravail ne cesse de prendre de l'ampleur ces dernières années, notamment depuis l'épisode du coronavirus, et est aujourd'hui au centre des préoccupations des directions informatiques.
- Un nombre croissant d'espaces de cotravail (ou co-working) ont également vu le jour, par souci de réduction des coûts immobiliers, et par volonté de flexibilité.

Cela amène à réfléchir sur la manière de sécuriser ces accès distants au système d'information(SI) de l'entité, afin de gérer les besoins de confidentialité et d'intégrité des données, ainsi que l'authentification des utilisateurs.

Face à ces enjeux, il est devenu important de sensibiliser l'ensemble des acteurs du nomadisme, et de prendre en compte dans la politique de sécurité des systèmes d'information (PSSI)

- *l'ouverture du SI de l'entité pour les accès distants;*
- *la maîtrise des nouveaux flux liés au nomadisme;*
- *la maîtrise des équipements de connexion des utilisateurs.*

Risque : Localisation des données

- **Le lieux** : le nomadisme apporte un degré d'exposition de l'information en raison de la localisation de l'utilisateur dans un lieu où la protection physique de l'environnement est inconnue, et globalement dépourvue du même niveau de sécurité de celui de l'entreprise : hôtel, lieu public, trajet domicile-travail, espace de co-working.

Aussi il est recommandé de considérer l'environnement de l'utilisateur nomade comme non maîtrisé.

Les risques principaux qui doivent être pris en compte sont :

- la perte ou vol de matériel;
- la compromission du matériel, par exemple pendant une absence temporaire de l'utilisateur;
- la compromission des informations contenues dans le matériel volé, perdu ou emprunté;
- l'accès illégitime au SI de l'entité (et donc la compromission de celui-ci);
- l'interception voire altération des informations (perte de confidentialité et/ou d'intégrité).

Risque : Localisation des données



Objectif

L'objectif d'un SI nomadisme est de réussir à tendre vers un niveau de sécurité le plus proche possible de celui du SI interne de l'entité, en répondant aux risques d'exposition plus forts listés ci-dessus.

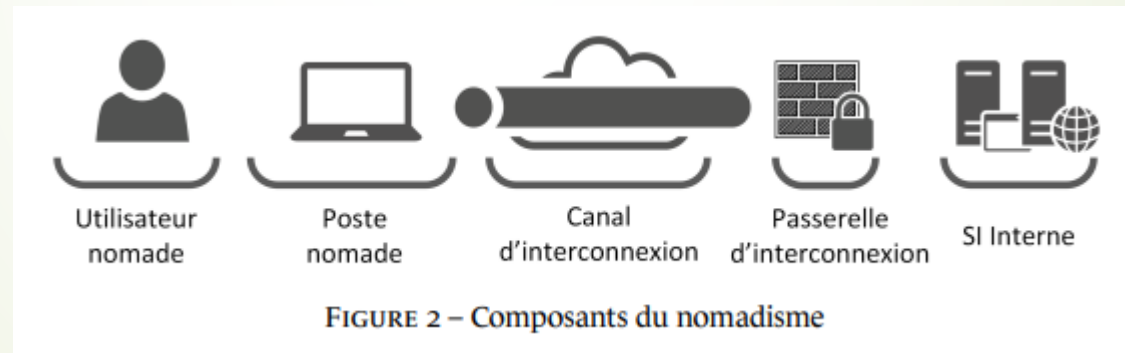
R1

Intégrer le nomadisme dans la PSSI de l'entité

L'entité doit mettre à jour sa PSSI, c'est-à-dire redéfinir les objectifs de sécurité à atteindre, les acteurs concernés ainsi que les moyens mis en œuvre pour accomplir la cible de sécurité de son SI nomadisme.

Démarche de réduction des risques

- Raisonner en terme d'architecture globale, ici la vue macro nous invite à nous intéresser aux éléments suivants :
 - l'utilisateur nomade;
 - l'équipement d'accès (ou poste de travail);
 - le canal d'interconnexion;
 - la passerelle d'interconnexion;
 - les ressources accessibles par les équipements nomades dans le SI interne de l'entité.



Démarche de réduction des risques

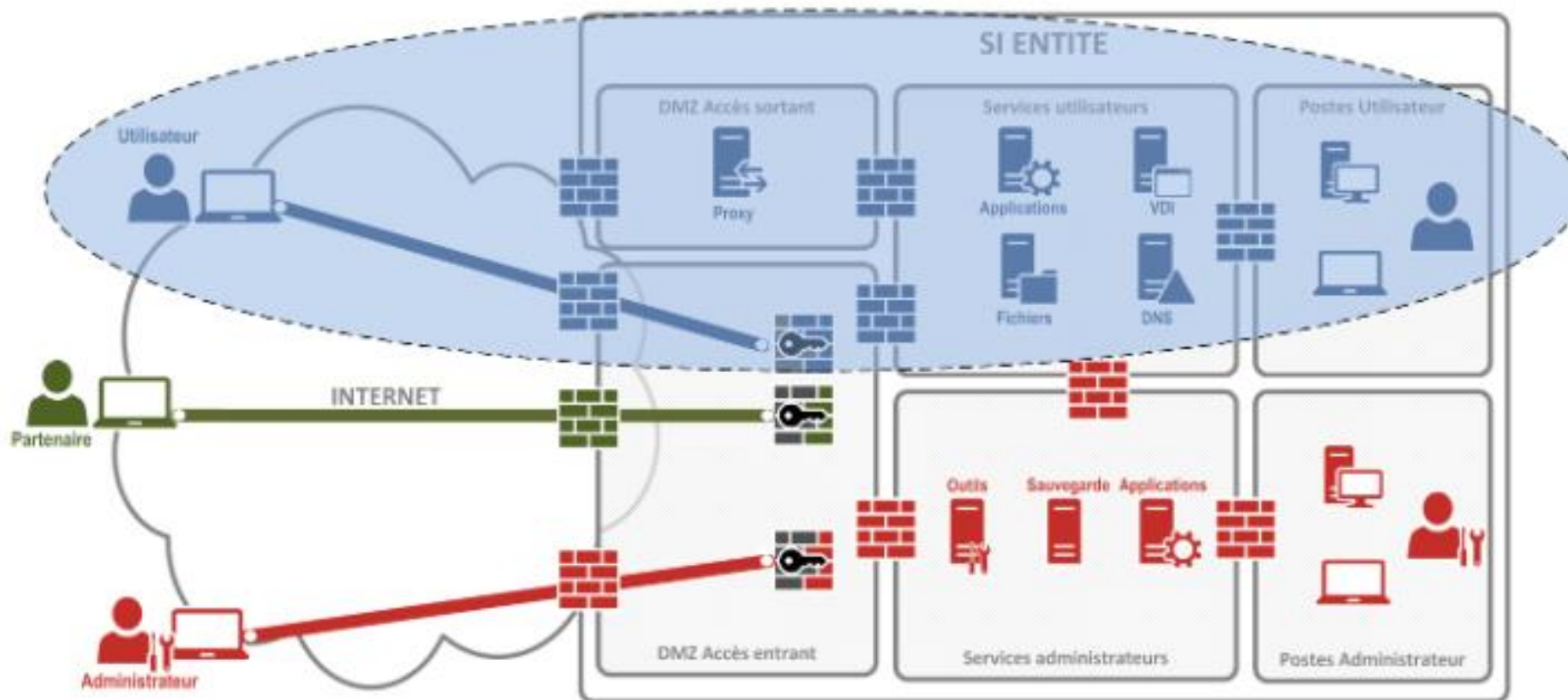
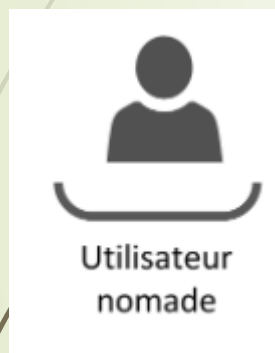


FIGURE 2.1 – Différents cas d'accès à distance et périmètre du guide

L'utilisateur nomade.



PHASE 1 INVENTAIRE E

Réaliser l'inventaire des activités des utilisateurs compatibles avec le nomadisme

Il est important d'identifier quels sont les métiers qui sont éligibles au nomadisme et au télétravail. Le travail en dehors des locaux de l'entité peut être interdit par exemple pour les raisons suivantes :

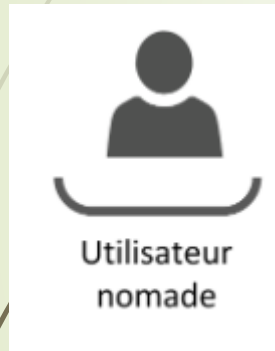
- parce que le niveau de sensibilité des données ou de l'activité est trop élevé ;
- pour des contraintes réglementaires ;
- parce qu'il existe des restrictions liées au métier (utilisation de matériel spécifique par exemple).

Maîtriser la gestion des utilisateurs nomades

Il faut documenter et mettre en place des procédures pour gérer correctement les changements dans le groupe d'utilisateurs nomades. Il faut définir au minimum des procédures pour les arrivées, les mutations et les départs des utilisateurs. Celles-ci doivent être formalisées, validées et appliquées strictement. Elles concernent notamment :

- la gestion et la révocation des comptes et des droits d'accès au SI nomadisme ;
- le changement de catégorie de l'utilisateur nomade ;
- la gestion des équipements mobiles nomades.

L'utilisateur nomade.



PHASE 2 SENSIBILISATION

Sensibiliser et former les utilisateurs nomades

Les utilisateurs doivent suivre des formations à la sécurité numérique. Ils doivent maîtriser parfaitement les outils, connaître les risques et les comportements à adopter en fonction de leur lieu de travail et des circonstances. La charte informatique de l'entité doit également intégrer les règles d'usage liées au nomadisme (p. ex. verrouiller sa session lorsque l'on laisse le poste sans surveillance, ne pas exposer la saisie de secrets à la vue d'autres personnes, etc.).

En effet, le comportement de l'utilisateur nomade est susceptible de provoquer des situations à risques, favorisant, par exemple :

- le vol ou la compromission de matériel et d'informations;
- des indiscretions et fuites d'informations.

L'utilisateur nomade.



Utilisateur
nomade

PHASE 3 POLITIQUE D'AFFECTATION DES EQUIPEMENTS

Dégradé À défaut - Renforcer la sécurité dans le cas de postes nomades partagés

Dans le cas où les postes nomades sont partagés, il est important de mettre en œuvre des mesures de sécurité complémentaires pour s'assurer d'un cloisonnement strict entre les utilisateurs partageant ces postes.

Dédier le poste nomade à un utilisateur nomade identifié

Chaque poste nomade doit être lié à un utilisateur nomade. L'utilisateur et le poste nomade doivent être identifiés dans le système de gestion d'équipements de l'entité³.

Dans un contexte d'utilisation nomade, il est fréquent que les équipements d'accès soient partagés entre plusieurs utilisateurs, si ces équipements ne sont utilisés que de façon ponctuelle par exemple.

Cependant, chaque utilisateur nomade doit être identifié et authentifié lorsqu'il se connecte au SI de l'entité. Le partage d'un poste de travail rend la tâche de supervision plus compliquée pour les administrateurs, et pose également un problème de confidentialité entre les utilisateurs qui partagent le poste, pour les données présentes localement sur celui-ci.

Ainsi, il est fortement déconseillé de mettre en place des postes ou des comptes partagés pour la pratique du nomadisme.

L'équipement d'accès.



PHASE 1 MAITRISER LE POSTE [1 / 3]

Maîtriser le poste nomade de l'utilisateur nomade

Seuls les postes nomades gérés et configurés par les équipes informatiques de l'entité, ou un prestataire mandaté, doivent pouvoir être utilisés par les utilisateurs nomades. L'utilisation d'équipements personnels est à proscrire (BYOD).

Il est nécessaire de maîtriser complètement l'ensemble des équipements sur lesquels les utilisateurs nomades se connectent.

L'utilisation d'équipements personnels par l'utilisateur (AVEC en français ou BYOD en anglais) pour se connecter au SI de l'entité est donc à proscrire.

Cela est justifié entre autres pour les raisons suivantes :

- l'impossibilité de garantir le niveau de sécurité de l'équipement personnel;
- la multiplication des environnements utilisateur, qui rend la gestion du cycle de vie des applications difficile (navigateurs Web, interfaces homme-machine, etc.);
- la complexité de l'investigation en cas d'incidents.

L'équipement d'accès.



Equipement
d'accès

PHASE 1 MAITRISER LE POSTE [2 / 3]

Maîtriser le poste nomade de l'utilisateur nomade

Seuls les postes nomades gérés et configurés par les équipes informatiques de l'entité, ou un prestataire mandaté, doivent pouvoir être utilisés par les utilisateurs nomades. L'utilisation d'équipements personnels est à proscrire (BYOD).

Si le choix de l'entreprise se porte tout de même vers l'utilisation du **matériel personnel**, certains équipements permettent de mettre en œuvre un système de conteneur sécurisé et cloisonné, destiné à l'usage professionnel, comme par exemple :

- **Samsung Knox,**
- **Blackberry Dynamics.**

ou bien les conteneurs configurables dans les solutions de MDM tels que :

- **AirWatch**
- **MobileIron**
- **Ivanti**

Cependant, même si le conteneur professionnel dispose de fonctions de cloisonnement logique ou physique, et de chiffrement du conteneur, son utilisation reste partagée avec un système d'exploitation qui n'est pas protégé.

Il faut donc impérativement maîtriser l'ensemble de l'équipement, c'est-à-dire le conteneur dédié à l'usage professionnel, mais également la partie du système qui n'est pas protégée

L'équipement d'accès.



PHASE 1 MAITRISER LE POSTE [3 / 3]

Maîtriser le poste nomade de l'utilisateur nomade

Seuls les postes nomades gérés et configurés par les équipes informatiques de l'entité, ou un prestataire mandaté, doivent pouvoir être utilisés par les utilisateurs nomades. L'utilisation d'équipements personnels est à proscrire (BYOD).

De manière non exhaustive, il est possible de citer les mesures de restrictions suivantes :

- mettre en place un store privé d'entreprise et interdire l'installation manuelle d'applications;
- désactiver les services qui ne sont pas nécessaires d'un point de vue métier et qui sont potentiellement sources de menaces, comme la géolocalisation, le Bluetooth, le NFC, etc.;
- filtrer la navigation sur Internet.

De même, l'usage d'équipements professionnels fournis par l'entité pour des besoins personnels est à proscrire, ou bien à minima à encadrer strictement.

Dans tous les cas, il faut toujours considérer l'usage d'un équipement professionnel pour des besoins personnels comme dangereux et source de compromission

L'équipement d'accès.



Equipement
d'accès

PHASE 2 PROTECTION PHYSIQUE

Mettre à disposition des moyens de protection physique du poste nomade

L'entité doit mettre à disposition les moyens suivants pour protéger les postes nomades :

- un filtre écran de confidentialité (pour les PC portables, mais aussi pour les tablettes et les téléphones mobiles);
- des scellés pour identifier une éventuelle compromission matérielle;
- des verrous de ports USB et RJ45 si nécessaire;
- éventuellement un câble antivol.

L'équipement d'accès.



Equipement
d'accès

PHASE 3
CONTRÔLE
AU DEMARRAGE

Maîtriser l'intégrité de la séquence de démarrage du poste nomade

Il faut prendre des mesures de protection sur les éléments intervenant dans la séquence de démarrage du poste nomade :

- durcir la configuration de l'UEFI, notamment la possibilité de démarrer sur un autre système que celui prévu (USB, PXE, etc.);
- protéger l'accès à la configuration UEFI par un mot de passe robuste ;
- utiliser les fonctions de *Secure Boot UEFI* ;
- mettre en place la fonctionnalité de *Measured Boot* avec un maximum de PCR.

L'équipement d'accès.



Equipement
d'accès

PHASE 4 CHIFFRER LES DISQUES

Dégradé À défaut - Mettre en œuvre une solution de chiffrement de disque sans composant de sécurité physique

Si la solution de chiffrement ou le poste nomade ne permet pas l'utilisation d'un TPM et d'une carte à puce, un chiffrement du disque sans cette fonctionnalité doit être mis en place.

Un mot de passe permettant de lancer le déchiffrement du disque doit impérativement être demandé à l'utilisateur au démarrage du poste nomade.

Mettre en œuvre une solution de chiffrement de disque avec un TPM

Un chiffrement de disque doit être mis en place. Celui-ci doit concerner l'ensemble du disque (*Full Disk Encryption*) et mettre en œuvre des mécanismes cryptographiques à l'état de l'art.

Un mot de passe permettant de lancer le déchiffrement du disque doit être demandé à l'utilisateur au démarrage du poste nomade.

Un composant de sécurité physique TPM doit être utilisé pour protéger les clés de chiffrement et l'intégrité de la chaîne de démarrage (*Measured Boot*). Il est recommandé, si possible, d'associer le descellement du mot de passe utilisateur à la politique de descellement par PCR lors de la récupération du secret de déchiffrement du disque.

Enfin, si la solution logicielle le permet, le chiffrement du disque doit également être protégé en intégrité et en authenticité.

Renforcé Mettre en œuvre une solution de chiffrement de disque avec un TPM et une carte à puce

Si la solution de chiffrement et le poste nomade le permettent, il est recommandé de mettre en place le *Measured Boot* via le TPM, et de lier les opérations de descellement à une carte à puce. Un mot de passe ou code PIN lié à cette carte à puce doit être demandé à l'utilisateur au démarrage du poste nomade, afin de lancer le processus de déchiffrement du disque.

L'équipement d'accès.



PHASE 5 MAITRISER L'UTILISATION DES PERIPHERIQUES AMOVIBLES

Maîtriser la connexion de périphériques amovibles sur le poste nomade

Il est recommandé d'interdire la connexion de tout périphérique amovible et de bloquer tous les accès de ces périphériques (USB, lecteurs DVD, cartes SD, etc.) par le moyen le plus approprié. Si cette interdiction stricte n'est pas possible, il est important de mettre en œuvre des mesures de filtrage, de traçabilité et d'inspection antivirus pour l'utilisation de périphériques amovibles.

Si l'un ou plusieurs de ces besoins sont identifiés, il faut alors prendre des mesures de sécurité pour réduire les risques associés :

- connecter uniquement du matériel fourni par l'entité;
- bloquer techniquement l'utilisation d'autres matériels en filtrant les équipements autorisés et en vérifiant périodiquement l'inventaire des équipements amovibles autorisés;
- lorsque cela est possible, mettre en œuvre une fonction de reconnaissance de signature cryptographique entre le support amovible et l'équipement d'accès;
- inspecter systématiquement le contenu par des solutions antivirus lors de la connexion du support amovible et bloquer ce dernier ou le mettre en quarantaine en cas de fichier vérolé;
- journaliser les actions réalisées depuis les périphériques USB (montage, copie, suppression, accès aux fichiers, etc.);
- désactiver les fonctions de démarrage et d'exécution automatique (Autorun et Autoplay) sur les équipements d'accès.

L'utilisation de filtrage par Vendor ID, Product ID ou USB Serial Number est une mesure possible pour réduire les risques, mais celle-ci peut facilement être contournée par des outils d'usurpation d'identité USB (USB Spoofing). En l'absence de moyen d'authentification du matériel plus robuste, ce risque résiduel doit donc être assumé.

L'équipement d'accès.



Equipement
d'accès

PHASE 6 RESTRICTION DES PRIVILEGES

Interdire à l'utilisateur la modification de la configuration des moyens de protection et de connexion au SI de l'entité

Cette recommandation concerne tous les logiciels nécessaires à la connexion vers le SI de l'entité (p. ex. le client VPN) et les fonctions de protections associées (p. ex. le pare-feu local) installés sur le poste nomade de l'utilisateur.

Renforcé Établir le tunnel VPN automatiquement au démarrage du poste nomade et interdire toute action manuelle de l'utilisateur

L'établissement du tunnel VPN doit être réalisé automatiquement le plus tôt possible lors de la séquence de démarrage du poste nomade. Il est donc recommandé de préférer le mode automatique de type *device tunnel* au mode *user tunnel*. Ce processus est exécuté sans qu'il n'y ait possibilité pour l'utilisateur d'interagir et de modifier le comportement de celui-ci, ni au démarrage du poste nomade, ni ultérieurement pendant sa durée d'utilisation.

L'utilisateur ne doit pas être administrateur local de son poste.

L'équipement d'accès.



Equipement
d'accès

PHASE 6 DURCIR LES SYSTEMES

Réduire la surface d'attaque sur le système d'exploitation du poste nomade

De manière générale, il est recommandé de respecter les bonnes pratiques suivantes :

- utiliser uniquement des équipements initialisés à partir d'un standard d'installation propre à l'entité, c'est-à-dire une image de référence ou *master* ;
- n'installer que les logiciels et les modules strictement nécessaires ;
- réduire au strict besoin opérationnel le nombre de comptes locaux à privilèges ;
- désactiver les technologies non utilisées selon le contexte d'usage : Wi-Fi, réseau mobile (4G, 5G), Bluetooth, NFC, Thunderbolt, etc.

Désactiver IPv6 sur le poste nomade si celui-ci n'est pas nécessaire

Il est recommandé de ne pas laisser le protocole IPv6 activé sur le poste nomade si celui-ci ne nécessite qu'une connectivité réseau locale avec le protocole IPv4.

Mettre en œuvre les fonctions de sécurité du système d'exploitation sur le poste nomade

Il est recommandé d'utiliser les fonctions de sécurité des systèmes d'exploitation des postes nomades :

- Configuration des fonctions natives *Applocker*, *Windows Defender Exploit Guard*, *Device Guard*, *Credential Guard*, *Windows Defender Application Guard*, *LAPS* sur des systèmes Windows ;
- Application des recommandations du guide de l'ANSSI sur des systèmes Linux [4, 11].

L'équipement d'accès.



Équipement
d'accès

PHASE 6
METTRE EN
PLACE UNE
POLITIQUE DE
MISE EN
QUARANTAINE

Activer des mécanismes de mise en quarantaine et de remédiation pour les postes nomades non à jour des correctifs de sécurité

Il faut mettre en œuvre des mesures techniques permettant de bloquer temporairement toutes les connexions au SI interne de postes nomades non conformes à la politique de sécurité de l'entité. Il faut alors procéder à la mise à jour des postes nomades non conformes au moyen d'un ou plusieurs serveurs de remédiation (correctifs de sécurité, anti-virus, etc.) situés dans une zone isolée, au sein de la passerelle d'interconnexion par exemple.

L'équipement d'accès.



Equipement
d'accès

PHASE 7 VEROUILLAGE DU POSTE

Réduire la durée d'inactivité avant verrouillage automatique de la session utilisateur

La durée d'inactivité avant verrouillage automatique du poste nomade doit être un compromis entre la sécurité physique des situations de nomadisme et les besoins métier des utilisateurs. Il est recommandé que cette durée soit inférieure ou égale à 5 minutes.

Le canal d'interconnexion

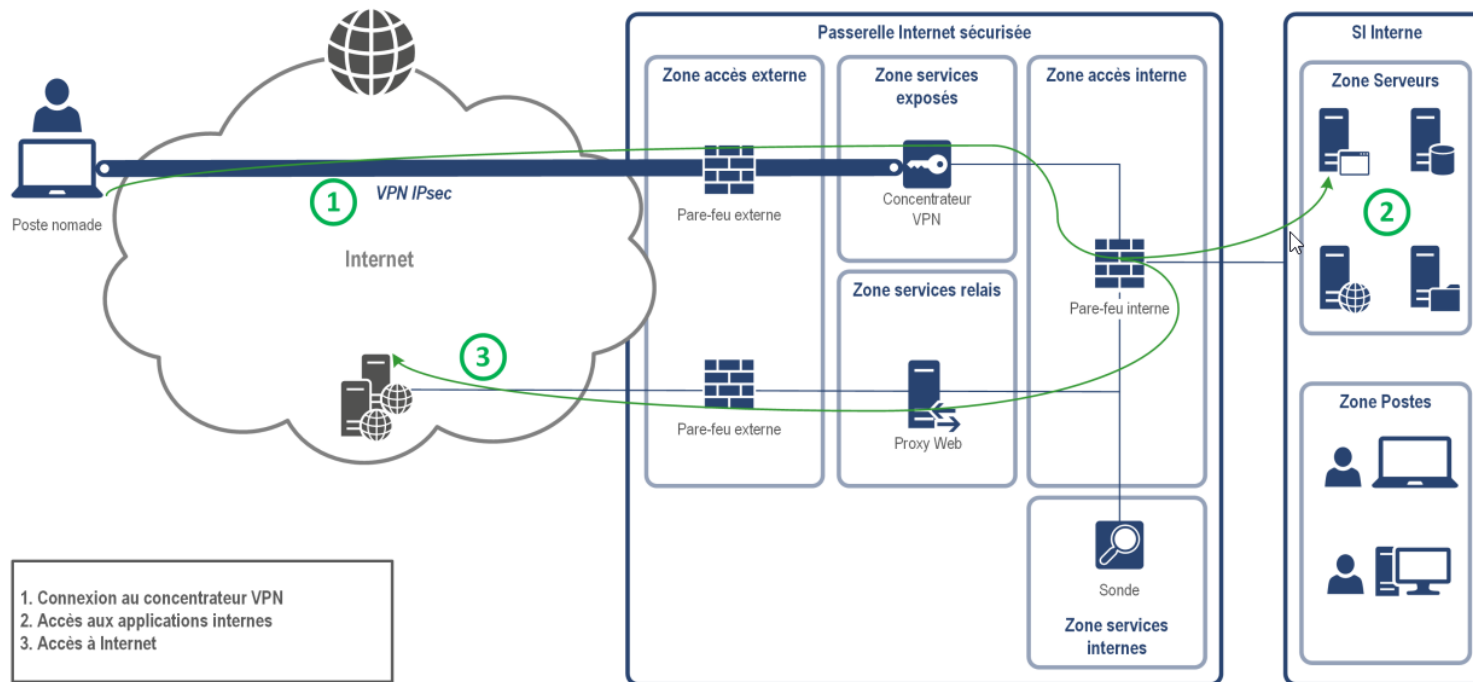


FIGURE 3 – Schéma général de connexion VPN nomade

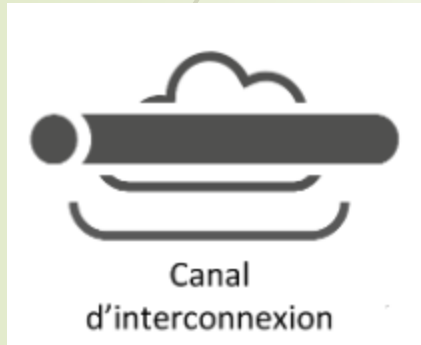
Le canal d'interconnexion doit être un lien sécurisé entre l'équipement d'accès et le SI de l'entité.

Il est composé :

- d'un client logiciel situé sur l'équipement d'accès (client VPN);
- d'un tunnel d'interconnexion VPN;
- d'un équipement de terminaison VPN.

Tous les flux en provenance et à destination de l'équipement d'accès doivent être maîtrisés.

Le canal d'interconnexion



PHASE 1 MISE EN PLACE D'UN VPN

Mettre en œuvre un tunnel VPN IPsec ou VPN TLS à l'état de l'art pour le canal d'interconnexion nomade

La solution VPN IPsec ou VPN TLS retenue doit être configurée à l'état de l'art, notamment les mécanismes de chiffrement et d'authentification mutuelle (se référer aux guides de l'ANSSI concernant les bonnes pratiques d'implémentation d'IPsec [19] et TLS [24]).

Renforcé Mettre en œuvre un tunnel VPN IPsec à l'état de l'art pour le canal d'interconnexion nomade

Dans le cas où les besoins de sécurité sont importants, il est préférable de s'appuyer sur une technologie de VPN IPsec, ce dernier étant par nature plus résistant aux méthodes d'attaque les plus sophistiquées. Il est recommandé de se référer aux deux guides IPsec [19] et IPsec DR [2] de l'agence pour le choix ou l'implémentation de cette technologie.

Tel qu'indiqué dans les guides, il est nécessaire de limiter les suites cryptographiques utilisées pour la négociation entre le client VPN et le concentrateur VPN, et n'autoriser que les suites cryptographiques les plus robustes. L'utilisation de TLS 1.3 est un moyen de s'assurer que des suites cryptographiques obsolètes ne sont pas utilisées.

Le canal d'interconnexion



PHASE 2 MAITRISE LES FLUX RESEAUX [1 / 4]

Activer le pare-feu local sur le poste nomade

Il est indispensable d'activer le pare-feu local sur le poste nomade pour bloquer tous les flux entrants et sortants, autres que ceux strictement nécessaires à l'établissement de la connexion VPN vers le SI de l'entité et répondant à des besoins métier spécifiques.

La liste des flux autorisés doit être revue régulièrement, notamment pour supprimer les règles obsolètes.

L'utilisateur ne doit pas avoir la possibilité de désactiver ou de modifier la configuration du pare-feu local sur le poste nomade.

Interdire le split-tunneling sur le poste nomade et autoriser les seuls flux nécessaires pour monter le tunnel VPN

Le *split-tunneling* doit être proscrit sur le poste nomade de l'utilisateur. Une fois le tunnel monté entre le poste nomade et le SI de l'entité, tous les flux doivent être acheminés uniquement vers le SI interne de l'entité.

Le canal d'interconnexion



PHASE 2 MAITRISER LES FLUX RESEAUX [2 / 4]

Dégradé À défaut - En cas d'usage du *split-tunneling* mettre en œuvre une configuration stricte visant à limiter les risques de compromission

Après analyse des risques, et à l'exclusion des SI d'administration, si la mise en place du *split-tunneling* sur le poste nomade est jugée acceptable, alors l'ensemble des conditions listées dans le tableau 2 doit être respectée.

Dégradé À défaut - N'autoriser la navigation Internet en *split-tunneling* sur le poste nomade que via un proxy de confiance

Dans le cas particulier de la navigation sur Internet, si l'entité fait le choix d'autoriser ces flux en *split-tunneling*, alors ces flux doivent impérativement transiter via une fonction *proxy*, qui peut être hébergée dans le SI interne de l'entité ou chez un prestataire. La configuration de ce proxy doit être sous la maîtrise de l'entité.

La mise en place du *split-tunneling* pour des administrateurs en situation de nomadisme est à proscrire, et ce, quel que soit le niveau de sensibilité du SI. En effet, les administrateurs disposent d'un niveau de privilège élevé sur le SI : l'accès à Internet est donc formellement proscrit sur leur poste d'administration, a fortiori à travers un mécanisme de *split-tunneling*.

Le canal d'interconnexion



Canal
d'interconnexion

PHASE 2 MAITRISER LES FLUX RESEAUX [3 / 4]

Bloquer les flux DNS vers Internet et configurer directement les adresses IP publiques des concentrateurs VPN sur le client

Il est recommandé de configurer le client VPN avec les adresses IP publiques des concentrateurs VPN de l'entité. Dans le cas où ce n'est pas possible, une résolution locale des noms des concentrateurs VPN peut être configurée sur le poste nomade (fichier *hosts*).

Dégradé À défaut - Sécuriser et maîtriser les flux DNS pour la résolution du nom du concentrateur VPN

Si l'utilisation de DNS est requise, il est conseillé de restreindre au maximum l'usage de la résolution DNS directement sur Internet, en utilisant un service DNS maîtrisé par l'entité ou par un prestataire de l'entité. Les flux DNS peuvent être sécurisés par l'ajout d'une fonction d'authentification et de contrôle d'intégrité, entre le client et le serveur de l'entité.

Dans un mode extrêmement dégradé, s'il n'est pas possible d'implémenter un service DNS propre à l'entité, l'entité peut faire le choix d'autoriser tous les flux DNS hors tunnel, afin de résoudre le nom des concentrateurs VPN par n'importe quel serveur DNS public. Il faut bien prendre conscience que ce choix revient à autoriser tout flux réseau à destination du port 53 sur Internet, ce qui représente un risque conséquent, qui doit être assumé par les responsables de sécurité de l'entité. Une fois le tunnel VPN établi, la configuration locale du poste nomade doit être modifiée automatiquement pour que toutes les résolutions DNS (publiques comme privées) soient réalisées en interne de l'entité, au travers du tunnel VPN.

Le canal d'interconnexion



Canal
d'interconnexion

PHASE 2
MAITRISE
LES FLUX
RESEAUX
[4 / 4]

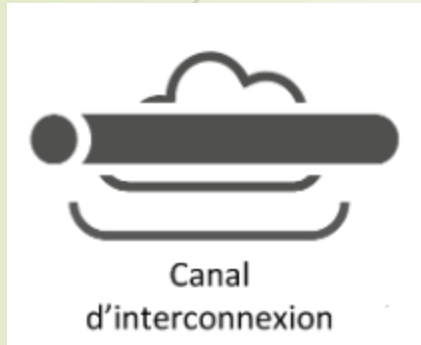
Configurer le client DHCP pour restreindre au strict nécessaire les paramètres à appliquer sur le poste nomade

Il est recommandé de configurer le client DHCP du poste nomade de manière à ne récupérer que les informations strictement nécessaires à l'établissement de la connectivité réseau du poste nomade (adressage réseau et passerelle par défaut). En particulier, il est important que les paramètres des serveurs DNS envoyés par le service DHCP ne remplacent pas les serveurs déjà configurés sur le poste nomade.

Bloquer l'accès aux portails captifs sur les postes nomades

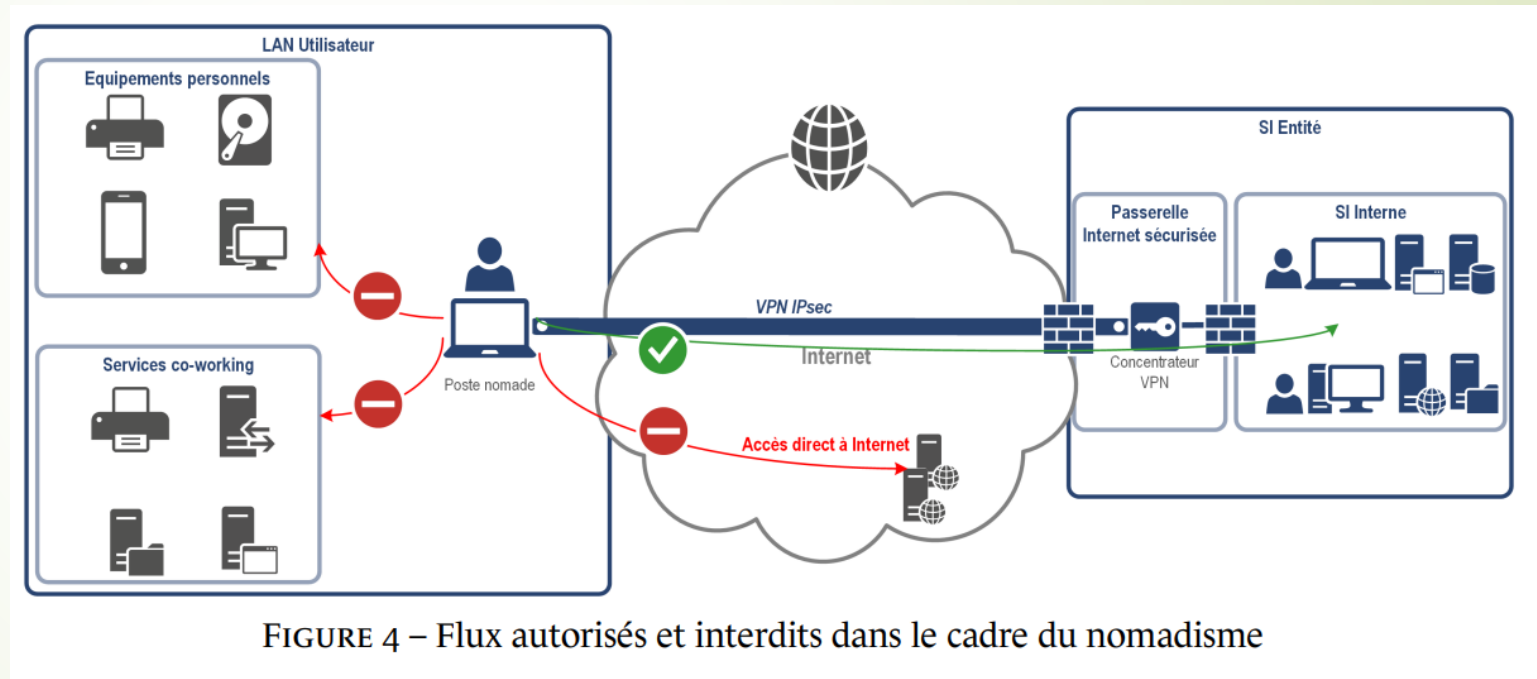
Pour réduire les risques de compromission des postes nomades, il est fortement recommandé de bloquer tous les flux directs HTTP et HTTPS. Ceci a pour conséquence d'interdire l'utilisation des portails captifs.

Le canal d'interconnexion

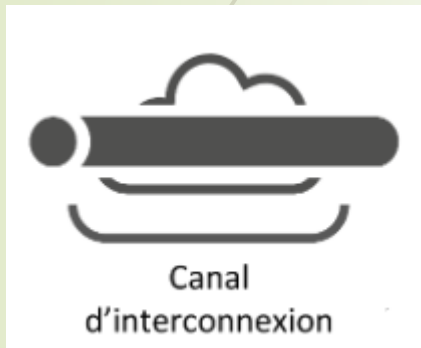


PHASE 2
MAITRISER
LES FLUX
RESEAUX

FINALITE



Le canal d'interconnexion



PHASE 3
ADAPTATION A
L'ENVIRONNEME
NT
[1/2]

Généraliser l'emploi de concentrateurs VPN pour les usages nomade mais aussi interne à l'entité

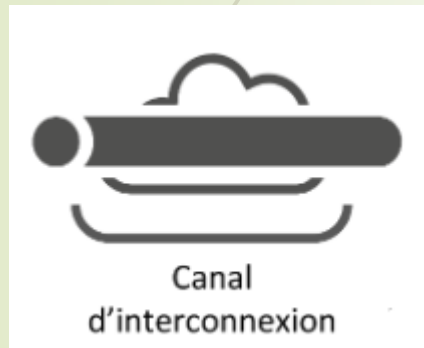
La mise en place de concentrateurs VPN internes permet de rationaliser et de simplifier la configuration réseau du SI et apporte une protection supplémentaire dans le cas des connexions des utilisateurs nomades en interne de l'entité.

Dégradé À défaut - Mettre en place un mécanisme de détection de l'environnement de l'utilisateur nomade

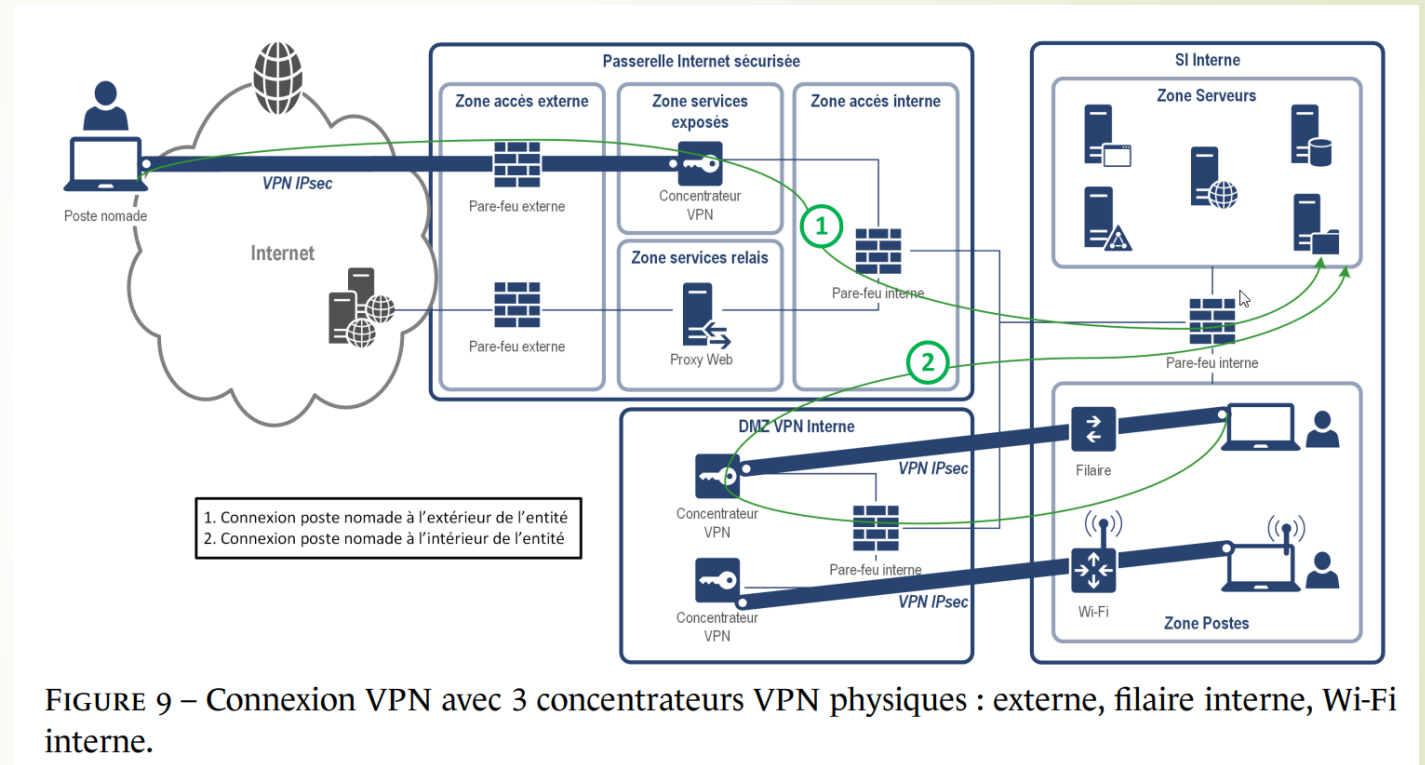
Si l'utilisation d'un mécanisme de détection de posture est nécessaire, l'outil retenu doit au minimum respecter les principes suivants :

- les contrôles de détection de posture doivent être fiables et les requêtes réalisées dans le cadre de ce contrôle doivent intégrer une fonction d'authentification robuste ;
- l'outil ne doit pas être débrayable par l'utilisateur ;
- l'outil doit permettre une journalisation de son utilisation ;
- l'utilisation de l'outil doit être documentée ;
- l'outil doit être exécuté au plus tôt dans la séquence de démarrage du poste nomade.

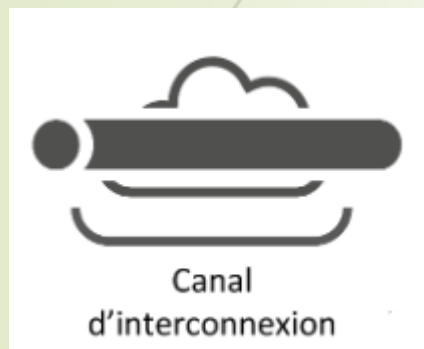
Le canal d'interconnexion



PHASE 3
ADAPTATION A
L'ENVIRONNEMENT
NT
[2/2]



Le canal d'interconnexion



DMZ ENTRANTE
DU SI NOMADE

FINALITE

Dédier physiquement des concentrateurs VPN respectivement pour les connexions nomades et internes au SI

Il est recommandé que les concentrateurs VPN internes et externes reposent sur des socles physiquement dédiés à chaque usage.

Renforcé Dédier physiquement un concentrateur VPN pour les connexions internes en Wi-Fi

Il est recommandé de disposer de concentrateurs VPN distincts par mode de connexion (Wi-Fi et filaire). Ces concentrateurs VPN doivent dans tous les cas être positionnés dans une ou plusieurs DMZ cloisonnées du SI Interne et dédiées à la fonction VPN.

Dégradé À défaut - Cloisonner logiquement par virtualisation les concentrateurs VPN mutualisés sur un même socle physique

En cas de mutualisation sur un même socle physique, les concentrateurs VPN doivent être cloisonnés par virtualisation (machines virtuelles ou *appliances* distinctes), afin de disposer de ressources et de configurations techniques propres à chaque usage.

Authentification



Passerelle
d'interconnexion

PHASE 1 L'AUTHENTIFICATION

Authentifier l'utilisateur sur le poste nomade

Il est recommandé de mettre en place une authentification de l'utilisateur sur le poste nomade, par exemple au moyen d'un mot de passe ou d'une carte à puce avec un code PIN.

Authentifier le poste nomade sur le SI

Il est recommandé d'authentifier le poste nomade sur le SI au moyen d'un certificat machine. Il est également recommandé de protéger la clé privée de ce certificat en intégrité et en confidentialité, afin de s'assurer qu'elle ne puisse être accédée ni par l'utilisateur nomade ni par un attaquant.

Authentifier l'utilisateur sur le SI

Il est impératif que l'utilisateur s'authentifie sur le SI, par exemple au moyen d'un mot de passe ou d'une carte à puce avec un code PIN. Cette authentification peut éventuellement être *mutualisée* avec l'authentification de l'utilisateur sur le poste nomade, dans le cas où la fonction permet la configuration d'un cache d'empreintes de mots de passe en local (p. ex. dans le cas d'un annuaire *Active Directory*).

Passerelles d'interconnexion



Passerelle
d'interconnexion

PHASE 2
MULTI FACTEUR

Mettre en place une authentification multifacteur forte pour l'utilisateur nomade

Il est recommandé de mettre en place une authentification multifacteur pour l'utilisateur nomade. Elle peut être implémentée par différents moyens (carte à puce, OTP sur un téléphone mobile, etc.) et à différentes étapes de l'authentification (ouverture de session, connexion au VPN, etc.).

Passerelles d'interconnexion



LE MODELE

FINALITE

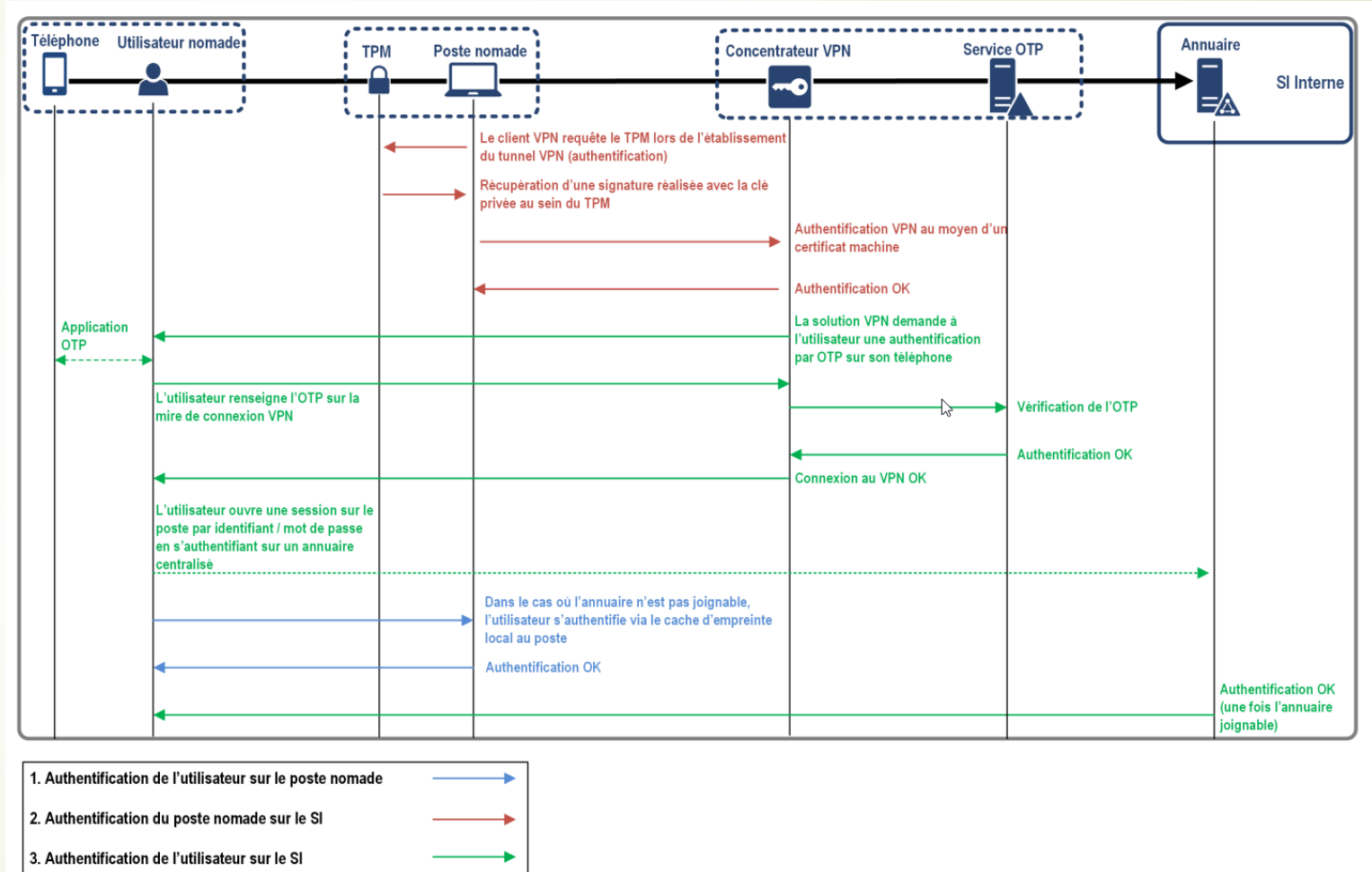


FIGURE 18 – Modèle d'authentification F

Passerelles d'interconnexion



Passerelle
d'interconnexion

GESTION DES CLES

Mettre en place une IGC maîtrisée par l'entité et dédiée au nomadisme

Il est recommandé de ne pas recourir à une IGC publique externe pour les besoins propres au nomadisme. L'IGC doit donc être maîtrisée par l'entité et ne pas être mutualisée avec d'autres besoins. Il est toutefois possible de déployer une ou plusieurs autorités intermédiaires dédiées au nomadisme et s'appuyant sur une IGC racine déjà existante au sein de l'entité.

Protéger les éléments secrets liés aux certificats nomades dans des composants sécurisés

Il faut s'assurer que le stockage des clés privées est sécurisé dans les différents contextes d'usage.

Pour le poste nomade, il est recommandé de stocker les éléments secrets sur une carte à puce sécurisée équipée d'un crypto-processeur, ou bien dans un composant TPM.

Pour le SI Interne ou la passerelle d'interconnexion (concentrateur VPN, IGC, etc.), il est recommandé d'utiliser un équipement HSM³³.

Configurer strictement l'autorité de certification légitime sur les postes nomades

Il est fortement recommandé de configurer le poste nomade et le client VPN de manière à ne faire confiance qu'à l'autorité de certification légitime pour monter le tunnel VPN entre le poste et le SI de l'entité.

Passerelles d'interconnexion



Passerelle
d'interconnexion

VALIDITE DES
CERTIFICATS

Vérifier la validité des certificats client et concentrateur VPN via le mécanisme d'agrafage OCSP

Cette vérification doit se faire avant que l'établissement de la connexion VPN ne soit complet. Cette fonction doit faire partie de l'analyse de risque à mener pour le nomadisme.

Dégradé À défaut - Vérifier la validité des certificats concentrateurs VPN par l'ouverture d'un flux direct sur le poste nomade ou par une mesure organisationnelle

Si l'agrafage OCSP n'est pas la solution retenue, il est recommandé de mener une analyse de risque pour choisir la meilleure alternative dans ce cas précis.

Passerelles d'interconnexion



LE PROCESSUS
DE VALIDATION

FINALITE

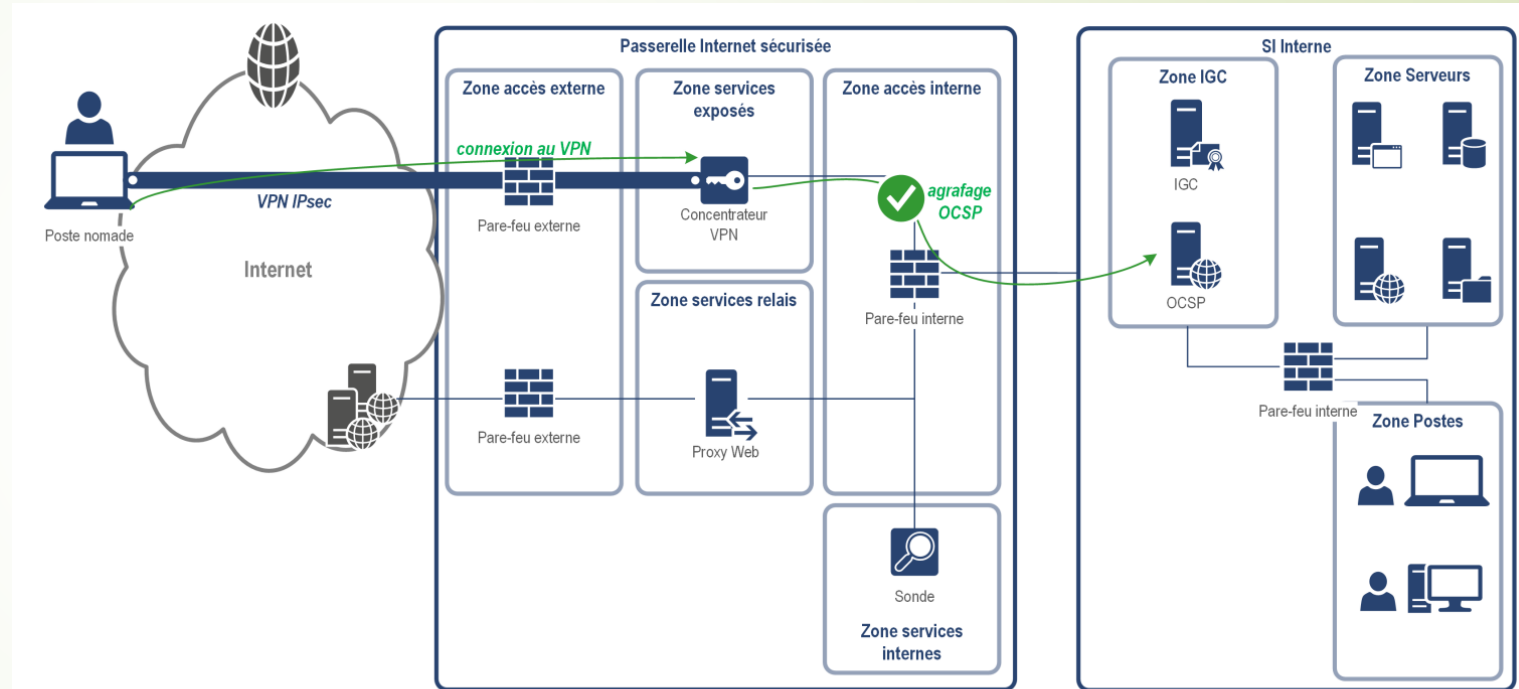


FIGURE 19 – Vérification de la validité des certificats des concentrateurs VPN par agrafage OCSP

Passerelles d'interconnexion



Passerelle
d'interconnexion

LE CLOISENEMENT [1 / 2]

Implémenter des fonctions de sécurité complémentaires au sein de la passerelle d'interconnexion du nomadisme

Il est recommandé de mettre en place des fonctions de sécurité indépendantes et complémentaires dans la passerelle d'interconnexion du nomadisme pour protéger le SI interne et réduire le risque d'une compromission depuis un poste nomade.

Mettre en place des équipements physiquement dédiés au nomadisme dans la passerelle d'interconnexion

Il est recommandé de dédier le matériel nécessaire à la connexion des utilisateurs nomades, au sein de la passerelle d'interconnexion.

Dégradé À défaut - Mettre en place un cloisonnement logique pour les fonctions de nomadisme dans la passerelle d'interconnexion

À défaut d'une infrastructure physique dédiée, il est fortement recommandé de cloisonner logiquement l'infrastructure de nomadisme du reste du SI de l'entité, par des fonctions de virtualisation, mais également par du chiffrement et du contrôle d'intégrité des flux.

Passerelles d'interconnexion



Passerelle
d'interconnexion

LE CLOISENEMENT [1 / 2]

Cloisonner physiquement chaque élément de la passerelle d'interconnexion lié au nomadisme

Il est recommandé de dédier le matériel pour chaque élément de la chaîne de connexion des utilisateurs nomades, au sein de la passerelle d'interconnexion.

Dégradé À défaut - Cloisonner logiquement chaque élément de la passerelle d'interconnexion lié au nomadisme

Il est recommandé d'avoir au minimum des machines virtuelles dédiées à chaque élément de la chaîne de connexion des utilisateurs nomades, dans le cas où celles-ci reposent sur un même socle physique.

Dédier un ou plusieurs socles physiques pour la fonction de pare-feu externe exposé à Internet

Il est recommandé que la fonction de sécurité la plus exposée (pare-feu externe) repose sur un ou plusieurs socles physiques dédiés.

Restreindre les fonctionnalités des pare-feux externes uniquement à du filtrage sur les couches réseaux

Le filtrage des pare-feux exposés à Internet ou pare-feux externes doit se limiter à du filtrage réseau (niveaux 3 et 4 du modèle OSI) et ne doit pas implémenter des fonctions de filtrage applicatif (niveaux 5 à 7 du modèle OSI).

Passerelles d'interconnexion



Passerelle
d'interconnexion

LES FLUX

Interdire tous les flux de communication directs entre les postes nomades

Il est fortement recommandé de configurer l'équipement de terminaison VPN de façon à ce que la communication entre les postes nomades au sein du même sous-réseau soit interdite. Toute connexion depuis le poste nomade doit passer impérativement par la passerelle d'interconnexion.

Passerelles d'interconnexion



LE
CLOISONNEMENT

FINALITE

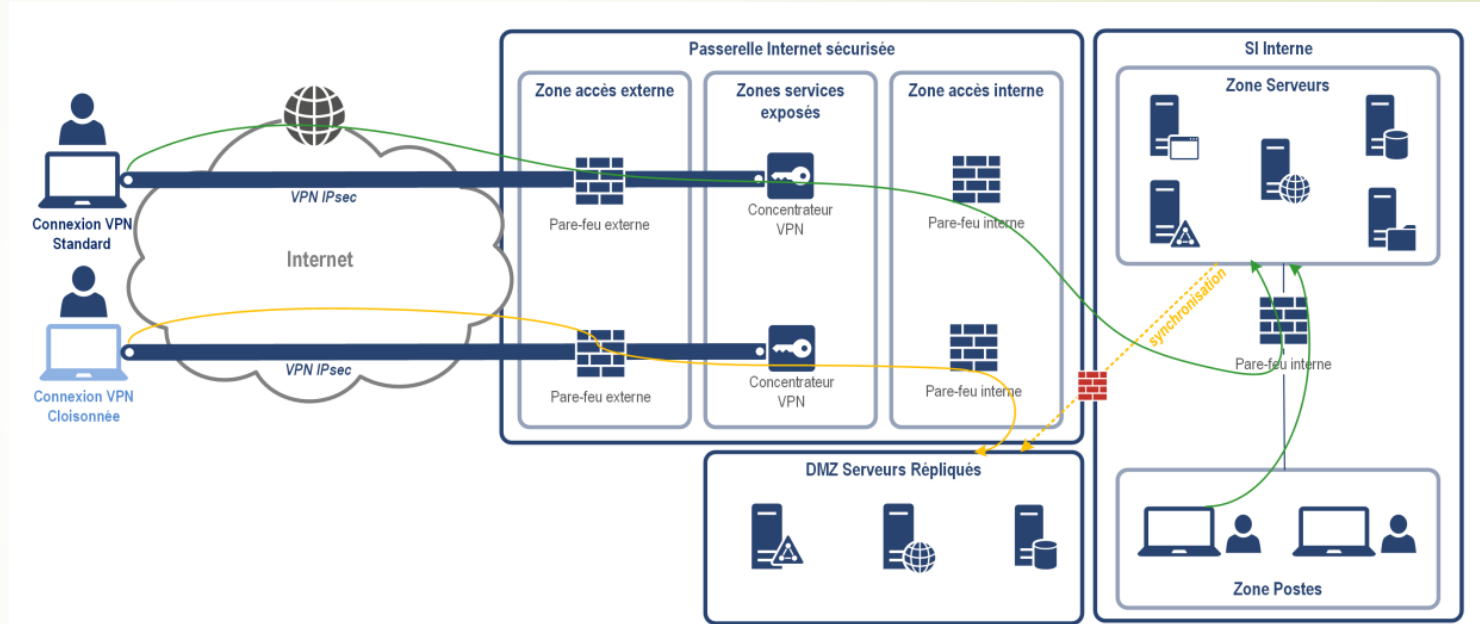


FIGURE 22 – Mise en place de services répliqués et cloisonnés pour les utilisateurs nomades à risque

Ressources du SI de l'entité



LES APPLICATIONS METIERS INTERNES

Ne pas exposer d'applications métiers directement sur Internet

Il est important de conserver la maîtrise de l'information et le besoin de confidentialité en n'exposant pas directement sur Internet les applications métiers. Celles-ci ne doivent être accessibles qu'une fois le poste nomade connecté au VPN de l'entité.

Dégradé À défaut - Authentifier les postes nomades avec une fonction dédiée en cas d'exposition d'applications métiers sur Internet

Dans le cas où des applications métiers sont directement exposées sur Internet, il est recommandé de limiter les accès à ces applications aux seuls équipements légitimes de l'entité. Cette mesure implique d'implémenter une fonction d'authentification des postes nomades reposant sur un service dédié et distinct de l'authentification applicative.

Passerelles d'interconnexion



LES
APPLICATIONS
METIERS
INTERNES

FINALITE

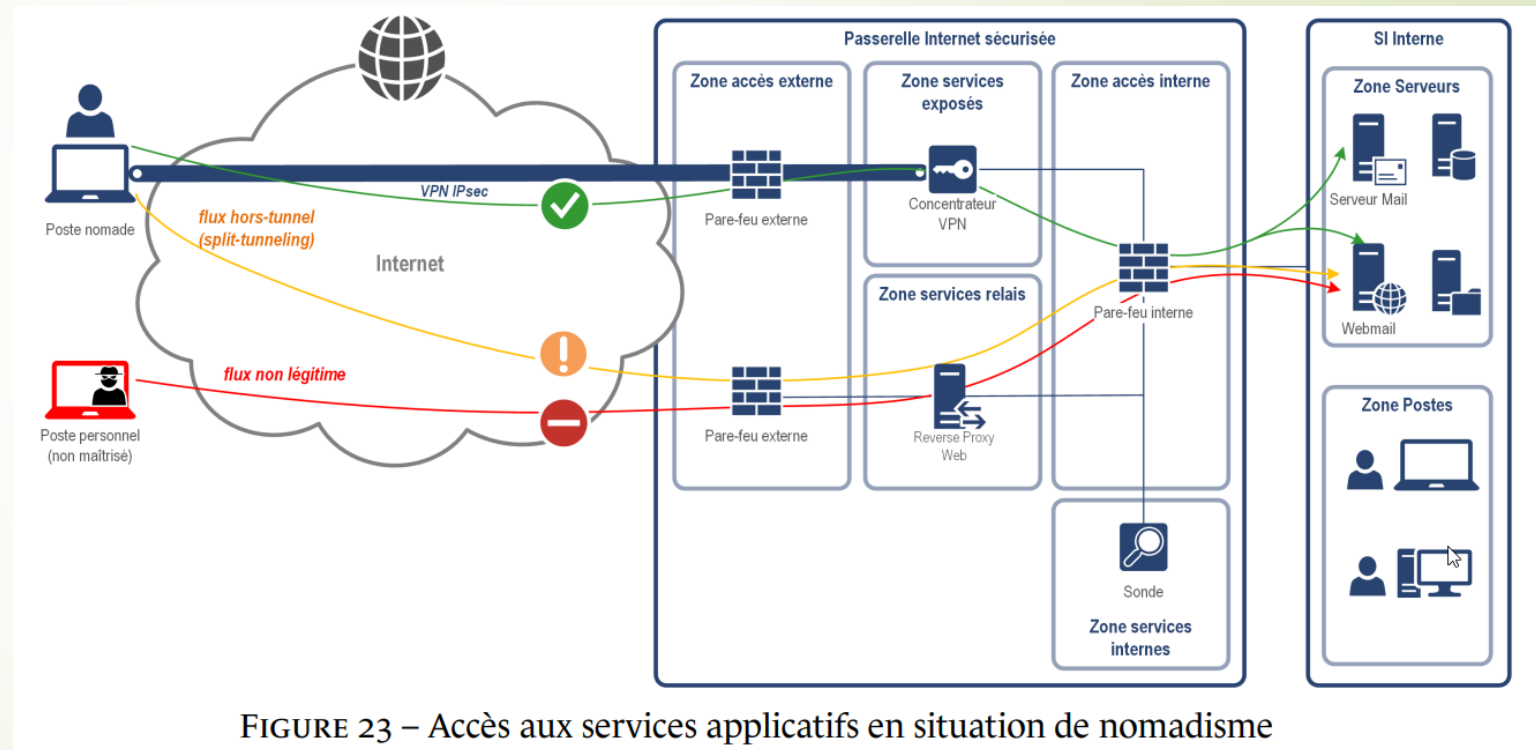


FIGURE 23 – Accès aux services applicatifs en situation de nomadisme

Ressources du SI de l'entité



LES
APPLICATIONS
METIERS CLOUD

Interdire un accès direct aux ressources présentes dans le cloud pour les utilisateurs nomades

De même que pour les applications internes, toutes les connexions des utilisateurs nomades aux applications *Cloud* doivent transiter par le tunnel VPN et uniquement par celui-ci.

Dégradé À défaut - Sécuriser les accès directs aux ressources présentes dans le cloud pour les utilisateurs nomades

Dans un mode dégradé, si la mise en place de *split-tunneling* pour des accès directs vers le *cloud* est retenue, il est recommandé que cet accès respecte les exigences de sécurité minimales relatives au chiffrement et à l'authentification des flux (p. ex. via l'usage de TLS à l'état de l'art), à la journalisation des connexions, ainsi qu'à un filtrage strict vers les services concernés.

Passerelles d'interconnexion



LES
APPLICATIONS
METIERS CLOUD

FINALITE

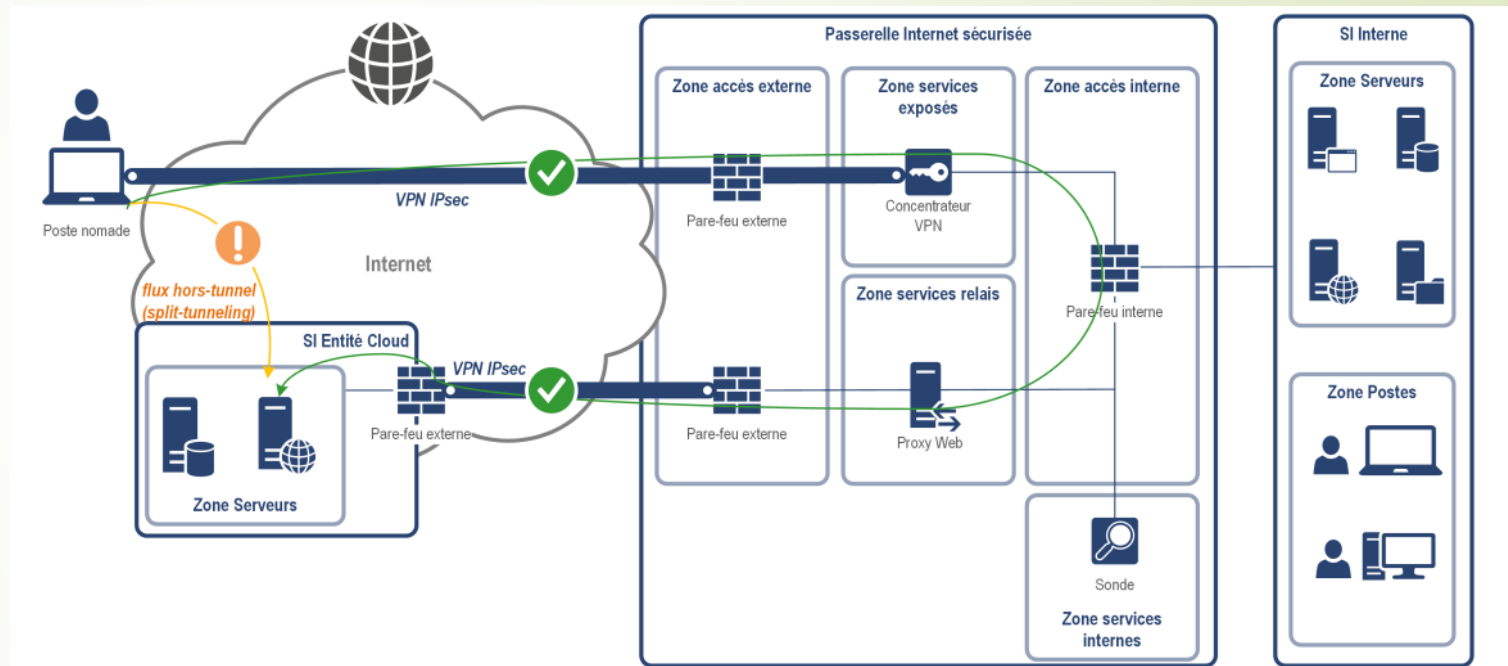


FIGURE 24 – Accès aux services applicatifs dans le cloud

Ressources du SI de l'entité



FILTRAGE

Réaliser un filtrage au sein de la passerelle d'interconnexion sur les applications autorisées en nomadisme

Ce filtrage peut s'opérer sur les pare-feux situés à la suite du concentrateur VPN, c'est-à-dire les pare-feux internes de la passerelle d'interconnexion à Internet. Dans une démarche de défense en profondeur, le filtrage réseau peut également être configuré en complément au niveau du pare-feu local du poste nomade.

Ressources du SI de l'entité



PROTOCOLE

Privilégier l'utilisation de protocoles chiffrés et authentifiés pour l'accès aux applications métier au travers du tunnel VPN

Pour tous les flux transitant au travers du tunnel VPN, il est recommandé de ne pas utiliser de protocoles sans chiffrement ni authentification (HTTP, FTP, TELNET, etc.), mais plutôt des protocoles sécurisés standards (HTTPS, SFTP, SSH, etc.).

Pour le transfert de fichiers, il est conseillé d'imposer les versions sécurisées de SMB ou NFS et de désactiver les versions obsolètes présentant des vulnérabilités connues.

Ressources du SI de l'entité



SYNCHRONISATION HORS LIGNE

Restreindre au strict besoin métier l'utilisation de la synchronisation de documents hors ligne pour les utilisateurs nomades

Le risque lié à la synchronisation de données entre le SI de l'entité et le poste nomade est à étudier avec soin. Il faut éviter de stocker localement des informations sensibles sur le poste nomade, si cela n'est pas nécessaire d'un point de vue métier.

Les recommandations de l'ANSSI



Privilégier l'utilisation de matériels et logiciels disposant d'un visa de sécurité de l'ANSSI

À chaque fois que cela est possible, il est recommandé de mettre en œuvre des matériels et des logiciels disposant d'un visa de sécurité de l'ANSSI au niveau adéquat.

Respecter les recommandations du guide d'administration sécurisée de l'ANSSI pour les ressources liées au nomadisme

L'administration des équipements liés au nomadisme doit suivre les recommandations formulées dans le guide de l'ANSSI [27].

Assurer le MCO et MCS des éléments contribuant au nomadisme

Il faut veiller à mettre en place au minimum un même niveau de maintien en condition opérationnelle et de sécurité pour le nomadisme que celui déjà existant pour le SI interne de l'entité. En particulier, cette politique doit prendre en compte et prioriser le MCO et le MCS des équipements exposés directement à Internet.

Prévoir une supervision de l'état de sécurité des postes nomades

La supervision des postes nomades doit permettre à l'entité de connaître leur niveau de sécurité et son évolution dans le temps. Il est recommandé de disposer d'une fonction de visualisation des principaux indicateurs et alertes concernant les postes nomades.

Les recommandations de l'ANSSI



Mettre en place une journalisation des différents éléments liés au nomadisme en suivant les recommandations des guides de l'ANSSI

La journalisation doit se faire sur tous les éléments liés au nomadisme (poste nomade, concentrateur VPN, etc.). Il est impératif que les journaux soient protégés en intégrité et ne puissent pas être modifiés par l'utilisateur nomade.

Privilégier le mode push pour la centralisation des journaux des équipements nomades

Il est recommandé d'utiliser le mode *push* pour l'envoi des journaux vers un collecteur centralisé. Ce flux doit être sécurisé (au moyen de TLS par exemple), filtré au moyen d'un pare-feu, et contrôlé par une fonction de détection.

Mettre en place un système d'analyse et de corrélation d'événements pour le nomadisme

Un système d'analyse et de corrélation d'événements (*SIEM*) doit être mis en place pour être en mesure de répondre aux incidents sur le SI. Ce système peut être intégré directement dans le système utilisé pour le SI interne de l'entité, si celui-ci existe déjà. Le système d'horodatage doit être unique et les équipements impliqués dans le nomadisme doivent se synchroniser avec les mêmes sources de temps.

Mettre en œuvre une sonde de détection dans le SI incluant les flux de nomadisme

Cette sonde doit être positionnée au sein de la passerelle d'interconnexion. Il est préférable de l'installer dans une zone dédiée, entre le concentrateur VPN et le pare-feu interne (comme représenté sur la figure 3). L'objectif est que la sonde soit en mesure d'analyser l'ensemble des flux entrants et sortants du SI interne de l'entité et également que cette analyse puisse se faire sur des flux déchiffrés (en sortie du concentrateur VPN).

BIBLIOGRAPHIE

SUPPORT EXCLUSIVEMENT ISSU DU DOCUMENT :

RECOMMANDATIONS SUR LE NOMADISME NUMÉRIQUE / GUIDE ANSSI